T E L E M E D I C I N E P L A T F O R M

Plataforma de Telemedicina

Documento de Análisis y Requisitos del Sistema

Versión: 1.0 (borrador para revisión)

Fecha: Octubre 2026

Clasificación: Confidencial

Audiencia: Equipo Técnico y de Producto

Marco de referencia: Hospital Virtual de México

Índice de Contenidos

Resumen Ejecutivo.....

Resumen Ejecutivo.....1

1. Introducción y Contexto del Proyecto.....2

1.1 Contexto del mercado de telemedicina.....2

1.2 Justificación del proyecto.....2

1.3 Análisis del sitio de referencia (Hospital Virtual de México).....3

1.4 Objetivos del proyecto.....3

1.5 Alcance y límites.....4

1.6 Glosario de términos (resumen).....4

2. Análisis del Mercado y Marco de Referencia.....4

2.1 Análisis funcional del sitio de referencia.....4

2.2 Benchmark comparativo.....5

2.3 Tendencias 2026 en telemedicina.....5

2.4 Oportunidades de diferenciación.....5

2.5 Stakeholders y mapa de actores.....6

3. Marco Regulatorio y de Cumplimiento.....6

3.1 Resumen del marco regulatorio multi-jurisdicción.....6

3.2 México: NOM-024-SSA3-2012, LFPDPPP y COFEPRIS.....6

3.3 Estados Unidos: HIPAA y HITECH.....7

3.4 Unión Europea: RGPD, MDR y eIDAS.....8

3.5 Estándares ISO/IEC aplicables.....8

3.6 Estándares de interoperabilidad.....9

3.7 Implicaciones de cumplimiento.....10

3.8 Cuadro comparativo de marcos regulatorios.....10

3.9 Estándares ISO/IEC aplicables.....10

3.10 Estándares de interoperabilidad....10
4. Stakeholders y Casos de Uso....11
4.1 Roles del sistema....11
4.2 Actores externos....11
4.3 Casos de uso críticos....11
4.4 Detalle de casos de uso críticos....11
5. Requisitos Funcionales por Módulo....12
5.1 Módulo de Autenticación e Identidad....12
5.2 Módulo de Gestión de Pacientes....12
5.3 Módulo de Gestión de Profesionales....13
5.4 Módulo de Citas y Agenda....13
5.5 Módulo de Videoconsulta....14
5.6 Módulo de Expediente Clínico Electrónico....14
5.7 Módulo de Recetas Digitales....15
5.8 Módulo de Pagos y Facturación....15
5.9 Módulo de Mensajería y Notificaciones....16
5.10 Módulo de Integraciones EHR....16
5.11 Módulo de Administración....17
6. Requisitos No Funcionales....17
6.1 Seguridad....17
6.2 Privacidad y protección de datos....18
6.3 Rendimiento....18
6.4 Disponibilidad....18
6.5 Usabilidad y accesibilidad....19
6.6 Compatibilidad....19
6.7 Internacionalización....19
6.8 Auditabilidad....19
6.9 Mantenibilidad y observabilidad....20

6.10 Resumen de requisitos no funcionales....20
7. Arquitectura Tecnológica....20
7.1 Patrón arquitectónico....20
7.2 Stack tecnológico recomendado....21
7.3 Componentes y microservicios....22
7.4 Modelo de datos conceptual....22
7.5 Integraciones externas....22
7.6 Estrategia de despliegue....23
7.7 Estrategia de seguridad por capas....23
8. Modelo de Negocio y Estrategia Comercial....23
8.1 Modelo de negocio dual....23
8.2 Líneas de ingreso....24
8.3 Estrategia de precios....24
8.4 Acuerdos BAA con proveedores cloud....24
8.5 Modelo de partners....24
8.6 Proyección cualitativa de adopción....25
9. Matriz de Riesgos y Plan de Mitigación....25
9.1 Catálogo y matriz de riesgos....25
10. Roadmap de Implementación por Fases....25
10.6 Resumen de fases....26
10.1 Fase 0 - Descubrimiento y Diseño (4 semanas)....26
10.2 Fase 1 - MVP (12 semanas)....26
10.3 Fase 2 - Beta Cerrada (8 semanas)....26
10.4 Fase 3 - Piloto Productivo (8 semanas)....27
10.5 Fase 4 - Escalamiento (12 semanas)....27
11. Equipo, Metodología y Estándares de Calidad....27
11.1 Equipo recomendado....27
11.2 Metodología....28

11.3 Estándares de calidad de código....28
11.4 Estrategia de pruebas....28
11.5 Gestión de la configuración y control de versiones....28
11.6 Pipeline CI/CD....29
12. Indicadores de Éxito y KPIs....29
12.1 KPIs de adopción....29
12.2 KPIs operativos....29
12.3 KPIs clínicos....29
12.4 KPIs financieros....30
12.5 Tablero de control....30
13. Conclusiones y Próximos Pasos....30
Anexo A. Matriz de Trazabilidad de Requisitos....31
Anexo B. Glosario y Referencias....32
B.1 Glosario de términos....32
B.2 Referencias bibliográficas y normativas....32

Nota: Este índice se genera mediante códigos de campo. Para actualizar los números de página tras editar el documento, haga clic derecho sobre el índice y seleccione "Actualizar campo".

Resumen Ejecutivo

El presente documento constituye la propuesta de análisis y requisitos para el desarrollo de una plataforma integral de telemedicina, concebida como un sistema multi-tenant de alta disponibilidad orientado al mercado mexicano y con vocación de expansión a Latinoamérica. La iniciativa toma como referencia funcional al sitio Hospital Virtual de México (hospitalvirtual.com.mx), que ofrece tres servicios principales —videoconsulta, consulta por mensaje y guardia virtual— y los extiende hacia una arquitectura completa con expediente clínico electrónico, recetas digitales con firma electrónica, pagos y facturación CFDI, mensajería clínica y un módulo de integración HL7/FHIR con sistemas EHR externos.

El alcance funcional abarca siete módulos no negociables: autenticación y gestión de identidad; videoconsulta con cifrado de extremo a extremo; agenda médica con sala de espera virtual; expediente clínico electrónico conforme a la NOM-024-SSA3-2012; recetas digitales con e.firma avanzada; pagos y facturación CFDI 4.0; mensajería asíncrona y notificaciones; e integraciones EHR mediante APIs FHIR R4. El stack tecnológico recomendado es de microservicios sobre Node.js (NestJS) en el backend, React 19 + Next.js 16 en el frontend, PostgreSQL 16 con Prisma ORM como base de datos principal, Redis para caché y colas, y un SFU WebRTC (mediasoup) para video en tiempo real.

El marco regulatorio adoptado es multi-jurisdicción: NOM-024-SSA3-2012 y LFPDPPP para México; HIPAA Privacy/Security Rule y HITECH para Estados Unidos; RGPD y MDR para la Unión Europea; y los estándares ISO/IEC 27001, ISO 14971 e ISO 27799 como base internacional. La plataforma se diseñará desde el origen con controles que permitan certificar cumplimiento y habilitar acuerdos BAA con proveedores cloud HIPAA-eligible.

El análisis comparativo con Hospital Virtual, Teladoc, Doctoralia y Amwell identifica oportunidades de diferenciación en interoperabilidad FHIR nativa, gestión de recetas controladas conforme a la normatividad mexicana, y un marketplace de APIs similar al del sitio de referencia pero con documentación OpenAPI 3.1 y SDKs oficiales. El roadmap propuesto se estructura en cinco fases —Descubrimiento, MVP, Beta cerrada, Piloto productivo y Escalamiento— con una duración estimada total de 44 semanas hasta el escalamiento multi-tenant.

Como conclusión preliminar, se considera que el proyecto es técnica y regulatoriamente viable, siempre que se cumplan tres condiciones críticas: (1) contratación temprana de asesoría legal especializada en salud digital; (2) firma de BAA con el proveedor cloud

seleccionado antes del inicio de la Fase 1; y (3) validación funcional con un comité clínico durante toda la Fase 0. Se solicita la revisión de este documento por parte del equipo de producto y tecnología antes de iniciar la fase de descubrimiento.

1. Introducción y Contexto del Proyecto

1.1 Contexto del mercado de telemedicina

La adopción global de servicios de telemedicina experimentó un crecimiento acelerado a partir de 2020, pasando de ser una modalidad marginal a constituir una vía de atención habitual. De acuerdo con proyecciones de la Organización Mundial de la Salud y diversos analistas del sector salud digital, la telemedicina dejará de ser un canal alternativo para convertirse en un componente estructural de los sistemas sanitarios. Los factores que sostienen esta tendencia son el envejecimiento poblacional, la escasez de especialistas en zonas rurales, la presión por contener costos sanitarios y la aceptación generalizada de la atención remota por parte de los pacientes.

En México, la cobertura de servicios de salud presenta brechas significativas: la concentración de especialistas en zonas urbanas genera inequidad de acceso para la población rural y semiurbana. La telemedicina aporta un mecanismo de redistribución de la capacidad clínica existente, al permitir que un médico ubicado en una capital atienda pacientes en localidades distantes. Adicionalmente, el marco normativo mexicano ha evolucionado para reconocer la validez de la consulta médica remota, la receta electrónica y el expediente clínico electrónico, lo que reduce la incertidumbre regulatoria para nuevos desarrollos.

1.2 Justificación del proyecto

El proyecto se justifica en cuatro vectores. Primero, la oportunidad de democratizar el acceso a la atención médica especializada mediante una plataforma que opere en todo el territorio nacional. Segundo, la necesidad de un sistema que cumpla plenamente con la NOM-024-SSA3-2012 y la LFPDPPP, estándares que muchos actores del mercado solo cumplen parcialmente. Tercero, la viabilidad económica de un modelo de negocio dual B2C/B2B que combina consulta bajo demanda, suscripción para profesionales y licenciamiento white-label para instituciones. Cuarto, la oportunidad de diferenciación mediante un módulo de APIs para developers, replicando y mejorando la propuesta del sitio de referencia.

La plataforma no reemplazará la atención médica presencial en casos que requieran exploración física, procedimientos o urgencias vitales; su rol es complementario y queda delimitado a consultas de seguimiento, atención primaria, especialidades que no demanden examen físico, gestión de enfermedades crónicas y atención de urgencias menores.

1.3 Análisis del sitio de referencia (Hospital Virtual de México)

Hospital Virtual (hospitalvirtual.com.mx) es un sitio que opera como punto de encuentro entre pacientes y profesionales de la salud. Su propuesta se organiza en torno a tres modalidades de atención: videoconsulta (consulta sincrónica cara a cara vía web o aplicación móvil), consulta por mensaje (interacción asíncrona que permite compartir estudios y resolver dudas) y guardia virtual (atención de urgencias menores). El sitio está estructurado en secciones diferenciadas por audiencia: Paciente, Profesional de la Salud, Software para Instituciones, Servicios, Sitio para Developers, Ayuda y Contacto.

El flujo de atención visible para pacientes consiste en tres pasos: registrarse en la plataforma, solicitar una consulta online con el profesional de confianza y resolver el problema de salud en línea. Para profesionales, el flujo es: registrarse, configurar el perfil profesional y comenzar a atender pacientes en línea. El sitio menciona profesionales de todas las especialidades médicas, pero no publica un catálogo explícito, lo que sugiere un modelo de oferta abierta.

Las integraciones explícitamente mencionadas son video para consultas sincrónicas, mensajería para consultas asíncronas y compartir estudios médicos. No se mencionan integraciones concretas con pasarelas de pago, farmacias o laboratorios, ni se identifica la tecnología subyacente. La presencia de un sitio dedicado a developers sugiere la existencia o planificación de una API pública. El operador es Hospital Virtual, con aviso de privacidad y términos y condiciones publicados, y copyright 2026.

A partir de este análisis se identifican los siguientes puntos de mejora que la nueva plataforma puede incorporar: catálogo explícito de especialidades con perfil profesional verificable; integración con pasarelas de pago y facturación CFDI; módulo de recetas digitales con firma electrónica avanzada; expediente clínico electrónico conforme a NOM-024; integraciones HL7/FHIR documentadas; y una API para developers con documentación OpenAPI 3.1 y SDK oficiales.

1.4 Objetivos del proyecto

Objetivo general: diseñar, desarrollar y operar una plataforma de telemedicina multi-tenant, segura, escalable y conforme al marco regulatorio mexicano e internacional, que permita la atención médica remota de calidad entre pacientes y profesionales de la salud, con capacidad de integrarse con sistemas de información hospitalaria externos.

Objetivos específicos: (a) Implementar un módulo de videoconsulta con cifrado de extremo a extremo que garantice confidencialidad de la comunicación médico-paciente. (b) Construir un expediente clínico electrónico conforme a la NOM-024-SSA3-2012 con capacidades de captura, almacenamiento, recuperación y exportación. (c) Habilitar la emisión de recetas digitales con firma electrónica avanzada, incluyendo el manejo de medicamentos controlados con receta especial. (d) Integrar una pasarela de pagos con facturación CFDI 4.0 conforme a los requisitos del SAT. (e) Exponer APIs FHIR R4 para interoperabilidad con sistemas EHR externos. (f) Cumplir con los requisitos de HIPAA, RGPD y los estándares ISO/IEC 27001 e ISO 14971 aplicables. (g) Alcanzar un SLA de disponibilidad del 99,95% con RTO de 4 horas y RPO de 15 minutos.

1.5 Alcance y límites

El alcance del proyecto cubre el diseño y desarrollo del software de la plataforma, su despliegue en infraestructura cloud, la integración con servicios externos (pagos, SMS, WhatsApp, video, firma electrónica) y la documentación técnica y regulatoria necesaria para su operación.

Quedan fuera del alcance del proyecto: la prestación directa de servicios médicos (la plataforma es un medio, no un prestador); la certificación oficial ante COFEPRIS como producto médico si se determina que el software califica como Software as a Medical Device (SaMD) —esta certificación deberá gestionarse por separado; la operación de farmacias y laboratorios (su integración se limita a intercambio electrónico de información); y el desarrollo de aplicaciones móviles nativas completas en la Fase 1 (se prioriza web responsive y PWA, con apps nativas previstas para la Fase 3).

1.6 Glosario de términos (resumen)

Para garantizar la precisión conceptual, se presentan a continuación las siglas más relevantes utilizadas en el documento. El glosario completo se incluye en el Anexo B.

ECE: Expediente Clínico Electrónico. EHR: Electronic Health Record (Historia Clínica Electrónica en inglés). PHI/ePHI: Protected Health Information / electronic PHI. FHIR: Fast

Healthcare Interoperability Resources. HL7: Health Level Seven. SFU: Selective Forwarding Unit (componente de infraestructura WebRTC). BAA: Business Associate Agreement (acuerdo exigido por HIPAA). CFDI: Comprobante Fiscal Digital por Internet (factura electrónica mexicana). NOM-024: Norma Oficial Mexicana SSA3-2012. LFPDPPP: Ley Federal de Protección de Datos Personales en Posesión de los Particulares. SaMD: Software as a Medical Device. DPIA: Evaluación de Impacto en la Protección de Datos.

2. Análisis del Mercado y Marco de Referencia

2.1 Análisis funcional del sitio de referencia

El análisis funcional de Hospital Virtual de México se realizó sobre la versión pública del sitio (octubre 2026). Los hallazgos clave son los siguientes. Servicios principales: videoconsulta, consulta por mensaje y guardia virtual. Tipos de usuario atendidos: pacientes, profesionales de la salud, instituciones médicas, obras sociales, prepagas y empresas. La oferta de especialidades es abierta, sin catálogo publicado. No se detectan integraciones explícitas con pasarelas de pago, farmacias o laboratorios. Existe una sección denominada Software para Instituciones y otra para Developers, lo que sugiere un modelo B2B y una API pública en producción o planificada.

Como oportunidades de mejora identificadas sobre el sitio de referencia se destacan: incorporar verificación de cédula profesional ante la Dirección General de Profesiones; añadir transparencia sobre precios y tiempos de espera promedio; integrar pagos y facturación CFDI; implementar expediente clínico conforme a NOM-024; incorporar recetas digitales con firma electrónica; exponer APIs documentadas con OpenAPI; y publicar la política de cumplimiento normativo (HIPAA, LFPDPPP).

2.2 Benchmark comparativo

Se realizó un análisis comparativo con cuatro plataformas internacionales y regionales: Teladoc Health (EEUU), Doctoralia (Brasil/España), Amwell (EEUU) y MediSpace (Latinoamérica). Los criterios evaluados fueron: modalidades de atención, expediente clínico, recetas digitales, pagos, integraciones EHR, API pública, cumplimiento HIPAA/RGPD y presencia en mercados hispanohablantes.

Teladoc destaca por su escala y cumplimiento HIPAA pero su cobertura en Latinoamérica es limitada. Doctoralia es fuerte en marketplace de agendas pero carece de expediente clínico profundo. Amwell es una plataforma institucional orientada a hospitales, no a consumo

B2C. MediSpace ofrece cobertura regional pero su cumplimiento regulatorio es parcial. La oportunidad para la nueva plataforma radica en combinar la mejor experiencia de consumo tipo Doctoralia con la profundidad clínica tipo Amwell, todo bajo un marco regulatorio mexicano exhaustivo.

2.3 Tendencias 2026 en telemedicina

Las tendencias que se consideran estratégicas para el diseño del producto son cinco. Primero, la incorporación de asistencia de IA clínica para transcripción de notas, sugerencias diagnósticas y resúmenes de consulta, siempre con supervisión humana y de manera no determinante. Segundo, el monitoreo remoto de pacientes (RPM) mediante dispositivos conectados que reportan signos vitales, especialmente útil en enfermedades crónicas. Tercero, el value-based care, modelo de pago por resultados que exige captura de outcomes clínicos. Cuarto, la interoperabilidad FHIR R4 como estándar dominante para intercambio de datos clínicos. Quinto, la integración de determinantes sociales de la salud en el expediente, para enriquecer el contexto clínico.

2.4 Oportunidades de diferenciación

Las oportunidades concretas de diferenciación son: (a) Expediente clínico electrónico nativo conforme a NOM-024, sin necesidad de adaptaciones posteriores; (b) Marketplace de APIs documentadas con OpenAPI 3.1 y SDKs oficiales en JavaScript, Python y PHP; (c) Recetas digitales con manejo diferenciado de medicamentos controlados conforme a la normatividad mexicana; (d) White-label para instituciones con segregación multi-tenant estricta; (e) Integración nativa con WhatsApp Cloud API para notificaciones y mensajería asíncrona; (f) Cumplimiento multi-jurisdicción desde el diseño (México + HIPAA + RGPD) para soportar pacientes extranjeros y operación internacional.

2.5 Stakeholders y mapa de actores

Los stakeholders del proyecto se agrupan en cinco categorías. Pacientes: usuarios finales que demandan atención remota, con subsegmentos por edad, condición clínica y cobertura (particular, seguro privado, seguro público). Profesionales de la salud: médicos generales y especialistas que ofrecerán sus servicios a través de la plataforma. Instituciones: hospitales, clínicas, centros de salud, aseguradoras, prepagas y empresas que contratan el servicio para sus afiliados o empleados. Reguladores: COFEPRIS, Secretaría de Salud, INAI (Instituto Nacional de Transparencia, Acceso a la Información y Protección de Datos Personales) y SAT (Servicio de Administración Tributaria). Proveedores tecnológicos: cloud provider, pasarela

de pagos, proveedor de SMS/WhatsApp, proveedor de video, autoridad certificadora para e.firma.

El mapa de actores se completa con dos grupos secundarios: farmacias y laboratorios (como integraciones de intercambio de información) y asociaciones profesionales (para validación de catálogos clínicos).

3. Marco Regulatorio y de Cumplimiento

3.1 Resumen del marco regulatorio multi-jurisdicción

La plataforma operará inicialmente en México pero se diseñará desde el origen para cumplir con tres marcos regulatorios adicionales: HIPAA (Estados Unidos), RGPD/MDR (Unión Europea) y los estándares ISO/IEC internacionales. Esta decisión obedece a dos razones. Primero, los pacientes extranjeros que transitoriamente se encuentren en territorio mexicano pueden requerir atención y sus datos estarán sujetos a sus jurisdicciones de origen. Segundo, una arquitectura diseñada para el cumplimiento más exigente reduce el costo de expansión a nuevos mercados. La tabla de la subsección siguiente sintetiza los cuatro marcos y su aplicación al sistema.

3.2 México: NOM-024-SSA3-2012, LFPDPPP y COFEPRIS

La NOM-024-SSA3-2012 establece los objetivos funcionales y funcionalidades que deberán observar los productos de Sistemas de Expediente Clínico Electrónico y de Registro Electrónico para la Salud. Sus requerimientos aplicables al sistema incluyen: identificación inequívoca del paciente; captura de notas médicas con marca temporal y autoría; registro de signos vitales, antecedentes, medicamentos y notas de evolución; gestión de adjuntos (imágenes, estudios); exportación del expediente en formato interoperable; bitácora de acceso y modificaciones con trazabilidad inmutable; conservación del expediente por el periodo que determine la normatividad aplicable (mínimo cinco años); y mecanismos de control de acceso basados en roles.

La LFPDPPP (Ley Federal de Protección de Datos Personales en Posesión de los Particulares) regula el tratamiento de datos personales en México. Los datos de salud se consideran datos personales sensibles y exigen consentimiento expreso y por escrito del titular. La plataforma debe implementar: aviso de privacidad integral y simplificado; mecanismo para ejercer los derechos ARCO (acceso, rectificación, cancelación y oposición); evaluación de

impacto en privacidad; y notificación de brechas de seguridad al INAI y al titular en los plazos establecidos.

COFEPRIS regula los productos médicos y, dependiendo de la clasificación del software, la plataforma podría calificar como Software as a Medical Device (SaMD). Si la plataforma se utiliza para diagnóstico, tratamiento o prevención de enfermedades y sus decisiones clínicas son significativas, podría requerir registro ante COFEPRIS. En el presente documento se asume la clasificación inicial como SaMD Clase IIa (riesgo moderado), sujeta a confirmación por asesoría legal especializada.

Las recetas electrónicas en México deben cumplir con los requisitos del Código de Salud y las disposiciones del SAT respecto a la firma electrónica. Para medicamentos controlados (psicotrópicos y estupefacientes), la regulación exige receta especial con formato y controles adicionales. La plataforma debe distinguir entre receta ordinaria y receta de controlados, y aplicar los controles normativos correspondientes.

3.3 Estados Unidos: HIPAA y HITECH

HIPAA (Health Insurance Portability and Accountability Act) establece los estándares de privacidad y seguridad para la información de salud protegida (PHI/ePHI). La plataforma debe cumplir con la Privacy Rule (regla de privacidad), la Security Rule (regla de seguridad), la Breach Notification Rule (regla de notificación de brechas) y los requisitos de HITECH que ampliaron las obligaciones y aumentaron las sanciones.

Los controles técnicos exigidos por la Security Rule incluyen: control de acceso basado en roles (RBAC); auditoría de accesos y modificaciones; integridad de los datos (controles contra alteración indebida); transmisión de datos cifrada; cifrado en reposo (addressable, considerado best practice); y gestión de identificadores únicos de usuarios. Los acuerdos BAA (Business Associate Agreement) son obligatorios con todo proveedor que tenga acceso a PHI, incluyendo el cloud provider, el proveedor de video y la pasarela de pagos.

La regla de notificación de brechas exige notificar a los afectados, al Departamento de Salud y Servicios Humanos (HHS) y, en ciertos casos, a los medios de comunicación, dentro de los 60 días posteriores al descubrimiento de una brecha que afecte a más de 500 individuos.

3.4 Unión Europea: RGPD, MDR y eIDAS

El Reglamento General de Protección de Datos (RGPD/GDPR) regula el tratamiento de datos personales en la Unión Europea. Los datos de salud se consideran categoría especial (Artículo 9) y su tratamiento exige base jurídica explícita, generalmente el consentimiento

del titular. La plataforma debe implementar: evaluación de impacto en la protección de datos (DPIA); derechos de acceso, rectificación, supresión (derecho al olvido), portabilidad y oposición; diseño y configuración por defecto orientados a la privacidad; y notificación de breches a la autoridad competente dentro de las 72 horas.

El Reglamento de Dispositivos Médicos (MDR, Reglamento UE 2017/745) clasifica el software médico en clases I, IIa, IIb y III según el riesgo. Un software de telemedicina que asista en decisiones clínicas podría clasificarse como SaMD Clase IIa, requiriendo evaluación de conformidad por organismo notificado. Si la plataforma se limita a funciones administrativas (gestión de citas, mensajería) sin asistir en decisiones clínicas, podría clasificarse como Clase I.

El reglamento eIDAS establece los marcos para la identificación electrónica y los servicios de confianza, incluyendo la firma electrónica cualificada, que tiene el mismo valor legal que la firma manuscrita. Las recetas digitales para pacientes europeos deberán utilizar firma electrónica cualificada o, al menos, firma electrónica avanzada con sello de tiempo.

3.5 Estándares ISO/IEC aplicables

ISO/IEC 27001 (Sistema de Gestión de Seguridad de la Información): establece los requisitos para implementar, mantener y mejorar un SGSI. La plataforma adoptará los controles del Anexo A, especialmente los referentes a política de seguridad, organización, recursos humanos, control de acceso, criptografía, seguridad física, operaciones, comunicaciones, adquisición/desarrollo y gestión de incidentes.

ISO 14971 (Gestión de riesgos para productos sanitarios): obliga a identificar, analizar, evaluar y mitigar los riesgos asociados al uso del software médico. La matriz de riesgos del capítulo 9 de este documento constituye una primera aproximación a esta gestión.

ISO 27799 (Informática de la salud, seguridad de la información de la salud utilizando ISO/IEC 27002): guía la aplicación de los controles ISO 27002 en el contexto específico de la salud.

ISO 81060-series (medición no invasiva de la presión arterial): aplicable si la plataforma integra datos de tensiómetros conectados.

ISO 13485 (Sistemas de gestión de la calidad para productos sanitarios): aplicable si la plataforma se certifica como producto médico.

3.6 Estándares de interoperabilidad

HL7 v2: estándar legacy de intercambio de mensajes clínicos, todavía ampliamente utilizado en hospitales. La plataforma ofrecerá un conector HL7 v2 para integrarse con sistemas EHR existentes que no soporten FHIR.

FHIR R4 (Fast Healthcare Interoperability Resources, versión 4): estándar moderno basado en APIs RESTful y recursos JSON. La plataforma expondrá y consumirá recursos FHIR R4 para Patient, Encounter, Observation, MedicationRequest, DocumentReference y otros relevantes.

ICD-10/CIE-10 (Clasificación Internacional de Enfermedades, 10ª revisión): codificación diagnóstica estándar. La plataforma almacenará códigos CIE-10 en cada diagnóstico.

SNOMED CT: terminología clínica comprehensiva para signos, síntomas, procedimientos y hallazgos. Su uso se considera recomendado para enriquecer el expediente clínico.

DICOM: estándar para imágenes médicas. La plataforma aceptará adjuntos DICOM para estudios compartidos por pacientes, sin constituir un PACS (Picture Archiving and Communication System) completo.

3.7 Implicaciones de cumplimiento

Las implicaciones operativas del cumplimiento multi-jurisdicción son: (a) necesidad de un Compliance Officer dedicado durante todo el ciclo de vida del producto; (b) auditorías anuales de cumplimiento, internas y externas; (c) gestión documental rigurosa de políticas, procedimientos y evidencias; (d) clasificación y segregación estricta de datos por jurisdicción; (e) capacidad técnica de borrar datos por solicitud (derecho al olvido) sin comprometer la integridad del expediente clínico cuando la normativa sanitaria lo prohíba; (f) mecanismos de gobernanza de datos clínicos; y (g) capacitación obligatoria del personal en protección de datos y seguridad de la información.

3.8 Cuadro comparativo de marcos regulatorios

Jurisdicción	Norma principal	Datos sensibles	Firma electrónica	Notificación de brechas
México	NOM-024-SSA3-2012, LFPDPPP	Datos de salud = sensibles, consentimiento expreso	e.firma avanzada (SAT)	INAI y titular, plazo razonable

Jurisdicción	Norma principal	Datos sensibles	Firma electrónica	Notificación de brechas
Estados Unidos	HIPAA Privacy/Security Rule, HITECH	PHI/ePHI protegida, consentimiento para algunos usos	Firma electrónica conforme a ESIGN Act	HHS y afectados, hasta 60 días
Unión Europea	RGPD, MDR, eIDAS	Datos de salud Art. 9, consentimiento expreso o base jurídica	Firma cualificada (eIDAS)	Autoridad competente en 72 horas

Tabla 1. Comparativo de marcos regulatorios por jurisdicción.

3.9 Estándares ISO/IEC aplicables

Estándar	Alcance	Aplicación en la plataforma
ISO/IEC 27001	Sistema de Gestión de Seguridad de la Información	Adopción del Anexo A, certificación objetivo año 2
ISO 14971	Gestión de riesgos de productos sanitarios	Proceso formal de identificación y mitigación de riesgos clínicos
ISO 27799	Seguridad de información en salud	Guía para aplicación de controles ISO 27002 en contexto clínico
ISO 13485	Calidad para productos sanitarios	Aplicable si se certifica como producto médico
ISO 81060	Medición de presión arterial	Si se integran tensiómetros conectados

Tabla 2. Estándares ISO/IEC aplicables al proyecto.

3.10 Estándares de interoperabilidad

Estándar	Versión	Uso en la plataforma
HL7 v2	v2.5	Conector para sistemas EHR legacy
FHIR	R4	API nativa de intercambio de recursos clínicos
ICD-10/CIE-10	2019	Codificación diagnóstica

Estándar	Versión	Uso en la plataforma
SNOMED CT	Edición internacional	Terminología clínica comprehensiva
DICOM	3.0	Adjuntos de imágenes médicas
LOINC	2.7+	Codificación de observaciones de laboratorio

Tabla 3. Estándares de interoperabilidad adoptados.

4. Stakeholders y Casos de Uso

4.1 Roles del sistema

Los roles identificados en el sistema son siete. (1) Paciente: usuario final que solicita atención médica, accede a su expediente y gestiona sus citas. (2) Médico tratante: profesional que atiende consultas y mantiene el expediente clínico de sus pacientes. (3) Médico especialista: profesional que recibe interconsultas y atiende casos derivados. (4) Asistente/Recepcionista: gestiona agenda, confirmaciones y tareas administrativas bajo supervisión del médico. (5) Administrador institucional: gestiona usuarios, configuración y reportes de su institución. (6) Super-administrador: gestión global de la plataforma, multi-tenant. (7) Auditor: rol de solo lectura con acceso a bitácoras, expedientes anonimizados y reportes de cumplimiento.

4.2 Actores externos

Los actores externos al sistema son: aseguradoras y prepagas (reciben facturación y reportes de utilización); farmacias (reciben recetas electrónicas para dispensación); laboratorios (reciben órdenes y devuelven resultados); proveedores de identidad (proveedores OIDC/SAML para SSO institucional); pasarela de pagos (Stripe/Mercado Pago); proveedor de SMS/WhatsApp (Twilio, WhatsApp Cloud API); proveedor de video (mediasoup SFU); autoridad certificadora (para e.firma del médico); y autoridades reguladoras (COFEPRIS, INAI, SAT, HHS en caso de auditoría).

4.3 Casos de uso críticos

Se han identificado quince casos de uso críticos, descritos en la tabla siguiente con su identificador, actor principal, precondición, flujo principal resumido y postcondición. El detalle completo de cada caso de uso se entregará durante la Fase 0 como anexo técnico.

4.4 Detalle de casos de uso críticos

ID	Caso de uso	Actor principal	Precondición	Postcondición
UC-01	Registro de paciente con verificación de identidad	Paciente	El paciente aporta identificación oficial vigente	Cuenta creada, identidad verificada, expediente inicializado
UC-02	Registro de profesional con validación de cédula	Médico	El médico aporta cédula profesional vigente	Cuenta creada, cédula verificada ante DGP, perfil público
UC-03	Agendamiento de cita	Paciente	Médico con agenda disponible, paciente con método de pago configurado	Cita reservada, recordatorios programados, pago en autorización
UC-04	Reprogramación o cancelación de cita	Paciente o Médico	Cita existente en estado reservada	Cita actualizada, política de reembolso aplicada, notificaciones enviadas
UC-05	Ingreso a sala de espera virtual	Paciente	Cita confirmada, horario dentro de la ventana de tolerancia	Paciente en cola, médico notificado
UC-06	Inicio de videoconsulta	Médico	Paciente en sala de espera, consentimiento informado firmado	Sesión WebRTC cifrada E2EE iniciada, grabación condicional activada con consentimiento
UC-07	Captura de nota de evolución clínica	Médico	Videoconsulta en curso o finalizada	Nota almacenada en expediente, marca temporal, autor registrados

ID	Caso de uso	Actor principal	Precondición	Postcondición
UC-08	Emisión de receta digital ordinaria	Médico	Consulta finalizada, paciente identificado	Receta generada con firma electrónica, enviada al paciente, descargable en PDF
UC-09	Emisión de receta de medicamento controlado	Médico	Médico habilitado para controlados, receta especial	Receta especial generada con controles adicionales, reportable a autoridad
UC-10	Pago y facturación CFDI	Paciente	Consulta finalizada, datos fiscales capturados	Pago cobrado, CFDI 4.0 generado, enviado por correo y disponible en portal
UC-11	Solicitud de interconsulta	Médico tratante	Paciente con expediente, especialista disponible	Interconsulta creada, expediente compartido con consentimiento
UC-12	Acceso al expediente por paciente	Paciente	Paciente autenticado, expediente existente	Expediente mostrado en formato legible, acceso registrado en bitácora
UC-13	Derivación a especialista	Médico tratante	Interconsulta aceptada por especialista	Cita con especialista reservada, expediente compartido
UC-14	Exportación de expediente	Paciente o Médico	Expediente existente, justificación registrada	Expediente exportado en formato FHIR/JSON o PDF firmado

ID	Caso de uso	Actor principal	Precondición	Postcondición
UC-15	Mensajería asíncrona post-consulta	Paciente	Consulta realizada en los últimos 30 días	Mensaje enviado, notificación push al médico, respuesta registrada

Tabla 4. Casos de uso críticos del sistema (UC-01 a UC-15).

5. Requisitos Funcionales por Módulo

5.1 Módulo de Autenticación e Identidad

Este módulo gestiona la identidad de todos los usuarios de la plataforma, con verificación reforzada para profesionales de la salud. Soporta autenticación mediante usuario/contraseña, MFA (TOTP o SMS), Single Sign-On institucional mediante OIDC/SAML y verificación de identidad oficial para pacientes. Para médicos, realiza validación de cédula profesional ante la Dirección General de Profesiones (DGP) y verificación de habilitación ante las instituciones correspondientes.

Requisitos funcionales del módulo:

ID	Descripción	Prioridad	Criterio de aceptación
RF-AUTH-01	Registro de paciente con email y teléfono verificados	Must	Token OTP válido en ambos canales antes de activar cuenta
RF-AUTH-02	MFA obligatorio para profesionales y administradores	Must	Segundo factor configurado y verificado en primer login
RF-AUTH-03	SSO institucional mediante OIDC y SAML 2.0	Should	Login institucional funcional con proveedor configurado
RF-AUTH-04	Validación automática de cédula profesional ante DGP	Must	Cédula validada en menos de 24h, perfil marcado como verificado
RF-AUTH-05	Gestión de sesiones con expiración configurable	Must	Sesión expira tras 30 min inactividad o cierre explícito
RF-AUTH-06	Bloqueo temporal tras 5 intentos fallidos	Must	Cuenta bloqueada 15 min, notificación al titular
RF-AUTH-07	Recuperación de contraseña con token de un solo uso	Must	Token válido 15 min, contraseña nueva distinta a anteriores
RF-AUTH-08	Cierre de sesión en todos los dispositivos	Should	Tokens revocados en backend, sesión remota invalidada

5.2 Módulo de Gestión de Pacientes

Almacena y administra el perfil completo del paciente, incluyendo datos demográficos, antecedentes, contactos de emergencia, representantes legales (para menores o personas con discapacidad), cobertura médica y preferencias de comunicación. Permite al paciente actualizar sus datos no clínicos y al médico acceder a la información necesaria para la atención.

Requisitos funcionales del módulo:

ID	Descripción	Prioridad	Criterio de aceptación
RF-PAC-01	Perfil demográfico con CURP, RFC y datos de contacto	Must	Campos obligatorios validados, CURP con formato y dígito verificador
RF-PAC-02	Antecedentes clínicos editables por el paciente (no heredados)	Should	Sección separada de notas médicas, editable por el paciente
RF-PAC-03	Registro de representantes legales para menores	Must	Tutor con relación verificada, consentimiento documentado
RF-PAC-04	Gestión de coberturas médicas (seguro, prepaga)	Should	Múltiples coberturas, priorización, validación de vigencia
RF-PAC-05	Preferencias de comunicación y privacidad	Must	Opt-in granular por canal y tipo de notificación
RF-PAC-06	Carga de foto de perfil opcional	Could	Archivo JPG/PNG, máx 2 MB, almacenamiento cifrado
RF-PAC-07	Documento de consentimiento informado digital	Must	Plantilla por tipo de consulta, firma electrónica registrada

5.3 Módulo de Gestión de Profesionales

Administra el perfil profesional de médicos y otros profesionales de la salud: especialidades, subespecialidades, cédula, formación, biografía, idiomas, tarifas, disponibilidad y afiliaciones institucionales. Incluye un perfil público visible para los pacientes.

Requisitos funcionales del módulo:

ID	Descripción	Prioridad	Criterio de aceptación
RF-PRO-01	Perfil profesional público con especialidades y biografía	Must	Campos visibles configurables por el médico
RF-PRO-02	Configuración de tarifas por tipo de consulta y duración	Must	Tarifas editables, histórico de cambios
RF-PRO-03	Calendario de disponibilidad con bloques horarios	Must	Bloques configurables por día, excepciones, feriados
RF-PRO-04	Gestión de sobre-citas con duración configurable	Should	Múltiples pacientes en misma franja, reglas por especialidad
RF-PRO-05	Afiliación a múltiples instituciones	Should	Médico asociado a varias instituciones con roles diferenciados
RF-PRO-06	Certificados y diplomas cargables	Should	PDF firmado digitalmente, validación opcional
RF-PRO-07	Reputación y reseñas con moderación	Could	Reseñas post-atención, moderación antispam

5.4 Módulo de Citas y Agenda

Gestiona el ciclo completo de las citas: reservación, confirmación, reprogramación, cancelación, recordatorios, sala de espera virtual, no-shows y reembolsos. Incluye el motor de reglas que aplica políticas por institución, por médico y por tipo de consulta.

Requisitos funcionales del módulo:

ID	Descripción	Prioridad	Criterio de aceptación
RF-CIT-01	Reserva de cita con selección de médico, fecha y duración	Must	Disponibilidad consultada en tiempo real, bloqueo pesimista
RF-CIT-02	Recordatorios automáticos por SMS, WhatsApp y email	Must	Recordatorios 24h y 1h antes, configurables por paciente
RF-CIT-03	Política de cancelación y reembolso configurable	Must	Reglas por tiempo de antelación, penalización, excepciones
RF-CIT-04	Sala de espera virtual con cola ordenada	Must	Posición en cola visible, notificación al ingresar médico
RF-CIT-05	Check-in del paciente y admisión por médico	Must	Cambio de estado, registro de hora real vs programada

ID	Descripción	Prioridad	Criterio de aceptación
RF-CIT-06	Marca de no-show con política automática	Must	Tras 10 min de tolerancia sin check-in, marca aplicada
RF-CIT-07	Reprogramación con conservación de pago	Should	Cambio de fecha sin cobro adicional si cumple política
RF-CIT-08	Sobre-agenda con límite configurable	Should	Máximo de sobre-citas por médico/día

5.5 Módulo de Videoconsulta

Componente crítico para la atención sincrónica. Implementa videoconferencia WebRTC con SFU, cifrado de extremo a extremo, compartir pantalla y estudios, grabación opcional con consentimiento explícito, y manejo de reconexiones. La infraestructura SFU se selecciona para balancear calidad y costo, soportando escalado horizontal.

Requisitos funcionales del módulo:

ID	Descripción	Prioridad	Criterio de aceptación
RF-VID-01	Videoconsulta WebRTC con SFU propio	Must	Video HD 720p mínimo, audio Opus, latencia bajo 250ms
RF-VID-02	Cifrado de extremo a extremo (E2EE) opcional	Must	Claves derivadas por sesión, sin acceso de backend a contenido
RF-VID-03	Compartir pantalla y documentos durante la consulta	Must	Selector de ventana/pantalla, concesión revocable
RF-VID-04	Grabación con consentimiento explícito grabado	Must	Consentimiento documentado antes de iniciar grabación
RF-VID-05	Reconexión automática tras caída de red	Must	Hasta 3 intentos, conservación de estado
RF-VID-06	Diagnóstico de calidad de red antes de iniciar	Should	Test de ancho de banda, jitter, packet loss
RF-VID-07	Chat textual paralelo durante video	Must	Mensajes persistentes, adjuntos ligeros
RF-VID-08	Modo de baja conexión (audio + capturas)	Should	Conmutación automática a audio-only si video degrada
RF-VID-09	Marcadores clínicos (timestamped events)	Could	Médico marca momentos clave de la consulta

5.6 Módulo de Expediente Clínico Electrónico

Núcleo clínico de la plataforma, conforme a la NOM-024-SSA3-2012. Captura, almacena y gestiona todos los registros clínicos del paciente: notas de evolución, signos vitales, antecedentes, medicamentos, adjuntos y reportes. Implementa trazabilidad inmutable y exportación en formato interoperable.

Requisitos funcionales del módulo:

ID	Descripción	Prioridad	Criterio de aceptación
RF-ECE-01	Captura de notas de evolución con plantillas por especialidad	Must	Plantillas configurables, campos estructurados y texto libre
RF-ECE-02	Registro de signos vitales con rangos de normalidad	Must	Validación de valores fuera de rango, alertas en UI
RF-ECE-03	Antecedentes personales y familiares estructurados	Must	Catálogos SNOMED CT para codificación
RF-ECE-04	Listado de medicamentos activos con interacciones	Must	Verificación de interacciones en tiempo real
RF-ECE-05	Adjuntos multimedia (imágenes, PDF, DICOM)	Must	Cifrado en reposo, thumbnails, versionado
RF-ECE-06	Marca temporal y autoría inmutable en cada registro	Must	Hash criptográfico, bitácora inmutable
RF-ECE-07	Exportación del expediente en FHIR/JSON y PDF firmado	Must	Exportación completa, conforme a NOM-024
RF-ECE-08	Control de acceso basado en roles y relaciones	Must	Médico accede solo a pacientes bajo su cuidado
RF-ECE-09	Bitácora de acceso y modificaciones auditable	Must	Registro inmutable de cada acceso y modificación
RF-ECE-10	Retención por el periodo legal aplicable	Must	Mínimo 5 años, configurable por jurisdicción

5.7 Módulo de Recetas Digitales

Genera recetas electrónicas con firma electrónica avanzada del médico, incluyendo manejo diferenciado de medicamentos controlados con receta especial. Las recetas se envían al paciente y pueden enviarse directamente a farmacias asociadas. Cada receta incluye código QR de verificación para evitar falsificaciones.

Requisitos funcionales del módulo:

ID	Descripción	Prioridad	Criterio de aceptación
RF-REC-01	Receta electrónica con e.firma avanzada del médico	Must	Firma válida conforme a eIDAS/sAT, verificable
RF-REC-02	Catálogo de medicamentos con CIE-10 y código de barras	Must	Catálogo cargado desde fuente oficial
RF-REC-03	Receta especial para medicamentos controlados	Must	Formato y controles adicionales conforme a normatividad
RF-REC-04	Código QR de verificación anti-falsificación	Must	QR con firma digital, verificación online
RF-REC-05	Envío al paciente por email y WhatsApp	Must	PDF firmado, link de verificación
RF-REC-06	Envío directo a farmacia asociada	Should	Farmacia seleccionada por paciente, confirmación de recepción
RF-REC-07	Caducidad configurable por tipo de receta	Must	Receta ordinaria 30 días, controlados conforme a norma
RF-REC-08	Reportes a autoridad para controlados	Must	Envío automático a COFEPRIS según normatividad

5.8 Módulo de Pagos y Facturación

Procesa los pagos de las consultas, gestiona reembolsos, conciliación y facturación CFDI 4.0 conforme a los requisitos del SAT. Soporta planes y copagos para aseguradoras y prepagas, así como facturación a terceros pagadores.

Requisitos funcionales del módulo:

ID	Descripción	Prioridad	Criterio de aceptación
RF-PAG-01	Integración con Stripe y Mercado Pago	Must	Tokenización PCI-DSS, sin almacenamiento de PAN
RF-PAG-02	Autorización y captura diferida	Must	Autorización al reservar, captura al finalizar consulta
RF-PAG-03	Facturación CFDI 4.0 con complementos	Must	Generación vía PAC, envío al SAT en tiempo real
RF-PAG-04	Gestión de copagos y deducibles	Should	Cálculo según plan del paciente, facturación a pagador

ID	Descripción	Prioridad	Criterio de aceptación
RF-PAG-05	Reembolsos totales y parciales	Must	Política configurable, conciliación automática
RF-PAG-06	Conciliación bancaria automatizada	Should	Importación de extractos, matching por referencia
RF-PAG-07	Facturación consolidada para instituciones	Should	Factura única mensual con detalle por empleado
RF-PAG-08	Múltiples métodos de pago (tarjeta, transferencia)	Must	Soporte de tarjetas crédito/débito, SPEI

5.9 Módulo de Mensajería y Notificaciones

Habilita comunicación asíncrona entre pacientes y profesionales, interconsultas entre médicos, notificaciones push y alertas críticas. Las conversaciones se conservan como parte del expediente cuando están relacionadas con un caso clínico.

Requisitos funcionales del módulo:

ID	Descripción	Prioridad	Criterio de aceptación
RF-MSG-01	Chat asíncrono cifrado entre paciente y médico	Must	Cifrado en tránsito y reposo, adjuntos hasta 10MB
RF-MSG-02	Interconsultas entre profesionales con adjuntos	Must	Compartir expediente con consentimiento, hilo rastreable
RF-MSG-03	Notificaciones push web y móviles (FCM)	Must	Notificaciones segmentables, preferencias por usuario
RF-MSG-04	Alertas críticas con escalamiento	Must	Resultados críticos de laboratorio, escalamiento a supervisor
RF-MSG-05	Conservación de mensajes clínicos en expediente	Must	Mensajes relacionados con caso, archivados con marca temporal
RF-MSG-06	Mensajería por WhatsApp Business Cloud API	Should	Plantillas aprobadas, opt-in granular
RF-MSG-07	Traducción automática opcional	Could	ES/EN/PT, con advertencia de no clínica

5.10 Módulo de Integraciones EHR

Expone y consume APIs HL7/FHIR para interoperabilidad con sistemas EHR externos. Incluye un módulo para developers similar al del sitio de referencia, con documentación OpenAPI 3.1, SDKs oficiales y portal de administración de claves.

Requisitos funcionales del módulo:

ID	Descripción	Prioridad	Criterio de aceptación
RF-INT-01	API REST FHIR R4 para recursos clínicos	Must	Recursos Patient, Encounter, Observation, MedicationRequest
RF-INT-02	Conector HL7 v2 para sistemas legacy	Should	Parsing y mapeo a recursos FHIR internos
RF-INT-03	Portal de developers con documentación OpenAPI 3.1	Must	Swagger UI interactivo, ejemplos en 3 lenguajes
RF-INT-04	SDKs oficiales en JavaScript, Python y PHP	Should	Paquetes publicados en npm, PyPI, Packagist
RF-INT-05	Gestión de claves API con cuotas y rate limiting	Must	Claves por aplicación, revocables, métricas de uso
RF-INT-06	Webhooks para eventos clínicos	Should	Suscripción a eventos, reintentos con backoff
RF-INT-07	OAuth 2.0 con scopes FHIR SMART on FHIR	Should	Scopes clínicos granulares, consentimiento del paciente

5.11 Módulo de Administración

Centraliza la gestión de usuarios, roles, permisos, instituciones, configuración global, bitácora de auditoría y reportes. Es el módulo del super-administrador multi-tenant y de los administradores institucionales.

Requisitos funcionales del módulo:

ID	Descripción	Prioridad	Criterio de aceptación
RF-ADM-01	Gestión de usuarios con asignación de roles	Must	Roles multi-institucionales, herencia controlada
RF-ADM-02	Configuración multi-tenant con segregación estricta	Must	Datos aislados por tenant, sin fuga cruzada
RF-ADM-03	Bitácora de auditoría inmutable	Must	Append-only, hash encadenado, retención configurable

ID	Descripción	Prioridad	Criterio de aceptación
RF-ADM-04	Reportes operativos y de cumplimiento	Must	Dashboards predefinidos, exportación CSV/Excel
RF-ADM-05	Gestión de catálogos (especialidades, medicamentos)	Must	Carga masiva, validación, versionado
RF-ADM-06	Gestión de configuración por institución	Should	Políticas, plantillas, marcas blancas
RF-ADM-07	Gestión de feature flags por tenant	Could	Activación progresiva de funcionalidades

6. Requisitos No Funcionales

6.1 Seguridad

La plataforma aplica el principio de defensa en profundidad en múltiples capas. Cifrado en reposo AES-256 para bases de datos, volúmenes y backups, con gestión de claves mediante KMS dedicado. Cifrado en tránsito TLS 1.3 obligatorio en todos los endpoints, con HSTS y certificados gestionados por ACM. Para videoconsultas sensibles, se ofrece cifrado de extremo a extremo (E2EE) con claves derivadas por sesión que no se almacenan en el backend.

El endurecimiento del sistema sigue las prácticas OWASP Top 10: validación estricta de entradas, parametrización de consultas SQL vía ORM, cabeceras de seguridad (CSP, X-Frame-Options, X-Content-Type-Options), protección CSRF en formularios, y mitigación de XSS mediante sanitización. La gestión de identidad y acceso (IAM) implementa RBAC con roles jerárquicos, ABAC para permisos condicionales y principio de mínimo privilegio. MFA es obligatorio para profesionales, administradores y accesos desde IPs no habituales.

6.2 Privacidad y protección de datos

Los datos personales sensibles se segregan de los datos operacionales. La anonimización se aplica para análisis estadístico y agregados; la seudonimización se utiliza en entornos de desarrollo y pruebas, con prohibición de copiar datos productivos sin proceso de seudonimización validado. El derecho al olvido se implementa con reserva de los datos clínicos que la normatividad sanitaria exige conservar (cinco años mínimo en México), con borrado del resto de datos personales asociados. La portabilidad se implementa mediante

exportación FHIR/JSON. Se realiza DPIA antes del lanzamiento de cada módulo que procese datos sensibles.

6.3 Rendimiento

Los objetivos de rendimiento son: latencia de video por debajo de 250 ms en condiciones normales; tiempo de carga de página inicial (TTI) bajo 2 segundos en conexión 4G; capacidad de 1.000 consultas simultáneas activas en el MVP con escalado horizontal a 10.000+ en fases posteriores; tiempo de respuesta de APIs por debajo de 300 ms en el percentil 95; y generación de CFDI por debajo de 5 segundos. El sistema aplica cacheo en Redis para datos de catálogo, perfiles profesionales públicos y agendas; indexación optimizada en PostgreSQL; y CDN para assets estáticos.

6.4 Disponibilidad

El SLA objetivo es de 99,95% mensual, equivalente a un máximo de aproximadamente 22 minutos de indisponibilidad no programada. El RTO (Recovery Time Objective) es de 4 horas y el RPO (Recovery Point Objective) de 15 minutos. La estrategia de disaster recovery se basa en replicación multi-región activo-activo para datos críticos y activo-pasivo para datos secundarios, con failover automatizado. Se realizan backups incrementales cada 15 minutos y completos cada 24 horas, con retención de 30 días. Se llevan a cabo ejercicios de DR simulados trimestralmente.

6.5 Usabilidad y accesibilidad

La interfaz se diseña siguiendo WCAG 2.1 nivel AA: contraste mínimo 4.5:1, navegación completa por teclado, soporte para lectores de pantalla (NVDA, VoiceOver, TalkBack), etiquetas ARIA apropiadas, y redimensionamiento hasta 200% sin pérdida de funcionalidad. La interfaz es responsiva desde 320px (móvil) hasta 1920px (escritorio). El idioma principal es español de México, con soporte i18n para inglés (Estados Unidos) y portugués (Brasil) planificado en Fase 3.

6.6 Compatibilidad

Plataformas soportadas en Fase 1: navegadores Chrome, Edge, Firefox y Safari en sus dos últimas versiones mayores; iOS 15+ en Safari; Android 11+ en Chrome. Aplicaciones nativas móviles previstas para Fase 3. La plataforma se entrega como aplicación web responsive y

PWA instalable, con capacidades offline limitadas para visualización de expediente previamente sincronizado.

6.7 Internacionalización

El sistema soporta múltiples idiomas (es-MX, en-US, pt-BR) mediante archivos de mensajes JSON separados del código. Las fechas se muestran conforme al locale del usuario; los husos horarios se almacenan en UTC y se muestran convertidos al locale. Los formatos numéricos y de moneda respetan el locale. El almacenamiento de datos personales respeta los formatos locales (CURP en México, SSN opcional para EEUU).

6.8 Auditabilidad

Cada acceso, creación, modificación o eliminación de datos sensibles genera una entrada en la bitácora de auditoría, almacenada en un log append-only con hash encadenado que imposibilita la manipulación retrospectiva. La bitácora se conserva por un mínimo de cinco años. Los reportes de auditoría son exportables y se proporcionan al equipo de cumplimiento y a las autoridades cuando se requiera.

6.9 Mantenibilidad y observabilidad

El código sigue estándares de calidad: cobertura mínima de pruebas unitarias del 80%, análisis estático con SonarQube sin issues críticos, code review obligatorio en todos los pull requests, y pipeline de CI que bloquea merges con tests fallidos. La observabilidad se implementa con logs estructurados en formato JSON, trazabilidad distribuida con OpenTelemetry, métricas en Prometheus visualizadas en Grafana, y alertas en PagerDuty. Cada microservicio expone endpoints /health y /metrics estándar.

6.10 Resumen de requisitos no funcionales

ID	Requisito	Objetivo	Prioridad
RNF-01	Cifrado en reposo AES-256	Todos los datos sensibles cifrados	Must
RNF-02	Cifrado en tránsito TLS 1.3	Obligatorio en todos los endpoints	Must
RNF-03	E2EE en videoconsultas	Claves por sesión, sin acceso backend	Must
RNF-04	SLA disponibilidad	99,95% mensual	Must
RNF-05	RTO	4 horas	Must

ID	Requisito	Objetivo	Prioridad
RNF-06	RPO	15 minutos	Must
RNF-07	Latencia video	Menor a 250 ms	Must
RNF-08	Tiempo de carga TTI	Menor a 2 s en 4G	Must
RNF-09	Capacidad MVP	1.000 consultas simultáneas	Must
RNF-10	Capacidad objetivo	10.000+ consultas simultáneas	Should
RNF-11	Cobertura de pruebas	Mínimo 80%	Must
RNF-12	Accesibilidad WCAG	Nivel AA	Must
RNF-13	Idiomas soportados	es-MX, en-US, pt-BR	Should
RNF-14	Retención bitácora	Mínimo 5 años	Must
RNF-15	Tiempo respuesta API p95	Menor a 300 ms	Must

Tabla 5. Requisitos no funcionales (RNF-01 a RNF-15).

7. Arquitectura Tecnológica

7.1 Patrón arquitectónico

La plataforma adopta una arquitectura de microservicios sobre Node.js, con un API Gateway que centraliza autenticación, rate limiting y enrutamiento. Cada microservicio es autónomo, con su propia base de datos (database per service) cuando aplica, expone una API REST interna y se comunica con otros mediante eventos asíncronos a través de un bus de mensajes (NATS o Kafka) y llamadas sincrónicas cuando es imprescindible.

El frontend se sirve mediante un patrón BFF (Backend for Frontend): un BFF para la aplicación web del paciente, otro para la del profesional y otro para el portal administrativo. Esto permite optimizar las cargas y payloads para cada cliente sin sobrecargar el backend. La separación entre BFF y microservicios posibilita el despliegue y escalado independiente.

7.2 Stack tecnológico recomendado

Frontend: React 19 con Next.js 16 (App Router) como framework, TypeScript estricto, TailwindCSS para estilos, shadcn/ui para componentes, TanStack Query para gestión de estado servidor, Zustand para estado de cliente, y Playwright para pruebas E2E. La aplicación se entrega como PWA con capacidades offline para visualización de expediente.

Backend: Node.js 20 LTS con NestJS 11 como framework principal, TypeScript estricto, Prisma ORM para PostgreSQL, BullMQ para colas con Redis, Passport para autenticación, class-validator para validación. Cada microservicio expone su API con OpenAPI 3.1 autogenerada.

Base de datos: PostgreSQL 16 como base relacional principal, con extensiones pgcrypto para cifrado, pg_partman para particionado temporal de logs, y PostGIS para datos geográficos (cobertura de farmacias cercanas). Redis 7 para caché, colas y sesiones. OpenSearch para búsqueda full-text en expedientes y logs.

Video en tiempo real: mediasoup como SFU WebRTC, con TURN/STUN coturn para cruce de NAT. La grabación opcional se almacena cifrada en S3 con destrucción programada.

Mensajería: WhatsApp Cloud API oficial, Twilio para SMS y voz, Firebase Cloud Messaging para push móviles, Web Push para notificaciones del navegador.

Pagos y facturación: Stripe para tarjetas internacionales, Mercado Pago para LatAm, integración con PAC autorizado por SAT para CFDI 4.0.

Firma electrónica: integración con e.firma avanzada del SAT para médicos en México; para pacientes en otros países, integración con DocuSign o Adobe Sign conforme a eIDAS.

Infraestructura: Docker para contenedores, Kubernetes para orquestación (EKS en AWS o GKE en GCP), Terraform como IaC, GitHub Actions para CI/CD, ArgoCD para despliegue GitOps. Multi-región activo-pasivo en fase inicial, evolucionando a activo-activo en Fase 4.

7.3 Componentes y microservicios

Los microservicios identificados son doce: identidad (auth, gestión de sesión, SSO); pacientes (perfil, antecedentes, consentimientos); profesionales (perfil, especialidades, tarifas); agenda (citas, disponibilidades, recordatorios); video (sesiones, grabaciones); expediente (notas, signos vitales, adjuntos); recetas (generación, firma, controlados); pagos (Stripe/MP, CFDI, reembolsos); mensajería (chat, interconsultas); notificaciones (push, SMS, WhatsApp, email); integraciones (FHIR, HL7, webhooks); auditoría (bitácora inmutable, reportes).

Cada microservicio expone su API REST con documentación OpenAPI, registra métricas en Prometheus, envía logs estructurados a OpenSearch y trazas a OpenTelemetry. La comunicación entre servicios usa NATS para eventos asíncronos y gRPC/REST para llamadas sincrónicas.

7.4 Modelo de datos conceptual

Las entidades principales del modelo de datos son: Usuario (base para Paciente, Profesional, Administrador), Institución (tenant), Especialidad, Cita, VideoSesion, NotaEvolucion, SignoVital, Medicamento, Receta, Pago, FacturaCFDI, Mensaje, Interconsulta, Adjunto, BitacoraAuditoria. Las relaciones entre Paciente, Profesional y Cita constituyen el núcleo del modelo. El expediente clínico se modela como una colección de recursos FHIR relacionados con el paciente, permitiendo exportación directa a FHIR R4.

7.5 Integraciones externas

El mapa de integraciones externas incluye: cloud provider (AWS o GCP) para infraestructura; Stripe y Mercado Pago para pagos; PAC autorizado por SAT para CFDI; WhatsApp Cloud API para mensajería; Twilio para SMS y voz; Firebase para push; autoridad certificadora para e.firma; DGP para validación de cédulas; PACS hospitalarios mediante DICOM; EHR externos mediante FHIR R4 y HL7 v2.

7.6 Estrategia de despliegue

El despliegue se realiza en una nube HIPAA-eligible con BAA firmado. La topología inicial es activo-pasivo multi-región con failover automatizado. La infraestructura se provisiona con Terraform, los manifiestos de Kubernetes se gestionan con Helm, y los despliegues se automatizan con ArgoCD mediante patrón GitOps. El pipeline CI/CD ejecuta lint, tests unitarios, tests de integración, análisis SAST/DAST, build de imágenes, escaneo de vulnerabilidades, despliegue a staging, smoke tests y despliegue a producción con estrategia blue-green.

7.7 Estrategia de seguridad por capas

La seguridad se aplica en siete capas: perímetro (WAF, DDoS, rate limiting); red (VPC, security groups, NSG); aplicación (validación, OWASP, autorización); identidad (IAM, MFA, RBAC/ABAC); datos (cifrado, masking, tokenización); observabilidad (logs, SIEM, alertas); y procesos (gestión de incidentes, parcheo, capacitación).

8. Modelo de Negocio y Estrategia Comercial

8.1 Modelo de negocio dual

La plataforma opera con un modelo dual B2C/B2B. El segmento B2C atiende directamente a pacientes finales que pagan por consulta bajo demanda, con precios diferenciados por especialidad y duración. El segmento B2B atiende a instituciones (hospitales, clínicas), aseguradoras, prepagas y empresas que contratan el servicio para sus afiliados o empleados, con modelos de licenciamiento por usuario, por consulta o por institución.

Adicionalmente, la plataforma ofrece un modelo white-label mediante el cual una institución puede operar su propia marca sobre la infraestructura de la plataforma, con segregación estricta de datos y personalización visual.

8.2 Líneas de ingreso

Se identifican cinco líneas de ingreso principales. (1) Comisión por consulta: porcentaje variable según el canal de adquisición del paciente (orgánico, pagado, white-label). (2) Suscripción premium para médicos: tarifa mensual a cambio de herramientas avanzadas (agenda inteligente, plantillas clínicas, reportes). (3) White-label para instituciones: tarifa de licenciamiento por usuario activo mensual con mínimos comprometidos. (4) API tiered para developers: tiers gratuito, profesional y empresarial con cuotas diferenciadas. (5) Servicios complementarios: almacenamiento extendido de adjuntos, integraciones a medida, soporte prioritario.

Las líneas secundarias, sujetas a validación regulatoria, son: publicidad no intrusiva de servicios de salud asociados (farmacias, laboratorios) y comisiones por derivación a farmacias asociadas.

8.3 Estrategia de precios

La estrategia de precios se diseñará en la Fase 0 con validación de mercado. Las tarifas se mantendrán competitivas respecto a Hospital Virtual y otras plataformas regionales, con segmentación por especialidad (consultas generales con tarifa menor, especialidades con tarifa mayor) y por duración (15, 30 y 60 minutos). Para instituciones, los contratos serán personalizados según volumen y módulos activados. La aplicación de precios específicos se entregará como anexo separado para no contaminar este documento de requisitos.

8.4 Acuerdos BAA con proveedores cloud

Antes del inicio de la Fase 1, se firmará BAA (Business Associate Agreement) con el proveedor cloud seleccionado (AWS o GCP, ambos HIPAA-eligible). El BAA cubre el almacenamiento, procesamiento y transmisión de PHI/ePHI. Adicionalmente se firmarán BAAs con todos los subcontratistas que tengan acceso a datos de salud: proveedor de video, pasarela de pagos (si procesa datos del paciente), proveedor de SMS/WhatsApp, y PAC para CFDI.

8.5 Modelo de partners

Se establecen tres categorías de partners. Farmacias asociadas: reciben recetas electrónicas directamente y comparten datos de dispensación. Laboratorios asociados: reciben órdenes y devuelven resultados estructurados (LOINC). Aseguradoras y prepagas: reciben facturación, reportes de utilización y validan cobertura en línea. Cada partner se integra mediante APIs documentadas y contrato de 服务水平 (SLA) específico.

8.6 Proyección cualitativa de adopción

La proyección cuantitativa se entregará en un anexo financiero separado para evitar cifras no validadas. Cualitativamente, se espera una curva de adopción gradual: meses 1-3 con piloto controlado en una institución inicial; meses 4-9 con incorporación de profesionales individuales y crecimiento orgánico de pacientes; meses 10-18 con incorporación de instituciones medianas y white-label; y a partir del mes 18 con expansión geográfica a otras regiones de México y, posteriormente, a otros países latinoamericanos.

9. Matriz de Riesgos y Plan de Mitigación

Se identifican los riesgos más significativos del proyecto, agrupados en seis categorías. Cada riesgo se evalúa con su probabilidad (Alta/Media/Baja) e impacto (Crítico/Alto/Medio/Bajo) y se asigna un plan de mitigación. La matriz se revisará mensualmente durante el proyecto y se enriquecerá en cada fase.

9.1 Catálogo y matriz de riesgos

ID	Riesgo	Categoría	Prob.	Impacto	Mitigación
R-01	Clasificación SaMD Clase II o superior ante COFEPRIS	Regulatorio	Media	Crítico	Asesoría legal especializada en Fase 0, rediseño si es necesario
R-02	Fallo de cumplimiento HIPAA en auditoría	Regulatorio	Baja	Crítico	Auditoría externa pre-despliegue, BAA firmados, controles verificados
R-03	Brecha de seguridad con exposición de PHI	Seguridad	Baja	Crítico	Pentesting continuo, WAF, SIEM, plan de respuesta a incidentes
R-04	Indisponibilidad del SFU de video	Técnico	Media	Alto	Multi-región, failover automático, monitoreo proactivo
R-05	Retraso en integración con PAC para CFDI	Técnico	Media	Alto	Selección temprana del PAC, contrato con SLA, plan B alternativo
R-06	Baja adopción por parte de profesionales	Operativo	Media	Alto	Programa de onboarding, incentivos tempranos, soporte dedicado
R-07	Quejas por mala calidad de video	Operativo	Media	Medio	Diagnóstico de red pre-consulta, modo de baja conexión
R-08	Cambios regulatorios durante el desarrollo	Regulatorio	Media	Alto	Monitoreo regulatorio continuo, arquitectura flexible
R-09	Conflicto entre derechos del paciente y obligación de retención	Regulatorio	Alta	Medio	Asesoría legal, segregación de datos por jurisdicción
R-10	Pérdida de datos clínicos por error humano	Operativo	Baja	Crítico	Backups cifrados, DR multi-región, pruebas de restauración
R-11	Saturación del soporte ante pico de demanda	Operativo	Media	Medio	Escalado de soporte, autoservicio, base de conocimiento
R-12	Demora en validación de cédulas ante DGP	Operativo	Alta	Medio	Proceso paralelo manual, comunicación transparente al médico

ID	Riesgo	Categoría	Prob.	Impacto	Mitigación
R-13	Fallo en integración FHIR con EHR externo	Técnico	Media	Medio	Pruebas de integración tempranas, conector HL7 v2 como respaldo
R-14	Costo cloud superior a lo presupuestado	Financiero	Media	Medio	Monitoreo de costos, autoscaling, reserved instances
R-15	Reputacional por caso clínico adverso	Reputacional	Baja	Alto	Protocolo clínico claro, comunicación proactiva, seguros

Tabla 6. Catálogo de riesgos (R-01 a R-15) con plan de mitigación.

10. Roadmap de Implementación por Fases

El roadmap se estructura en cinco fases consecutivas con una duración estimada total de 44 semanas hasta el escalamiento multi-tenant. Las duraciones son orientativas y se ajustarán en la Fase 0 con la planificación detallada. Cada fase cuenta con objetivos, entregables principales, equipo sugerido y criterios de salida que deben cumplirse para iniciar la siguiente.

10.6 Resumen de fases

Fase	Nombre	Duración	Objetivo principal	Entregables clave
Fase 0	Descubrimiento y Diseño	4 semanas	Validar requisitos, arquitectura y regulatorio	Documento de diseño final, DPIA, plan de proyecto, selección de proveedores
Fase 1	MVP	12 semanas	Videoconsulta + agenda + expediente básico	Plataforma funcional sin pagos ni recetas, pruebas internas
Fase 2	Beta Cerrada	8 semanas	Pagos, recetas, mensajería, integración piloto	Plataforma completa con 50 usuarios beta, ajustes
Fase 3	Piloto Productivo	8 semanas	Despliegue productivo, certificación NOM-024	Sistema productivo, auditoría de cumplimiento, primera institución
Fase 4	Escalamiento	12 semanas	Multi-tenant, white-label, marketplace APIs	Plataforma escalable, expansión geográfica

Tabla 7. Fases del roadmap (Fase 0 a Fase 4).

10.1 Fase 0 - Descubrimiento y Diseño (4 semanas)

Objetivo: validar la viabilidad técnica, regulatoria y económica del proyecto, dejar listos los cimientos para el desarrollo. Entregables principales: documento de diseño arquitectónico detallado, DPIA (Evaluación de Impacto en Protección de Datos), selección de proveedores cloud y de integraciones, contratación de BAA, plan maestro de proyecto, presupuesto detallado y equipo conformado. Criterios de salida: diseño aprobado por equipo técnico y legal, BAAs firmados, equipo clave contratado, repositorio y pipeline CI/CD configurados.

10.2 Fase 1 - MVP (12 semanas)

Objetivo: entregar una plataforma funcional con los módulos de autenticación, pacientes, profesionales, agenda, videoconsulta y expediente mínimo, sin pagos ni recetas. Entregables principales: aplicación web responsive con login, gestión de perfiles, agenda y videoconsulta funcional, expediente con notas básicas y adjuntos. Criterios de salida: pruebas de carga aprobadas con 100 usuarios simultáneos, pruebas de seguridad OWASP sin issues críticos,UX testing con usuarios reales con score SUS sobre 75.

10.3 Fase 2 - Beta Cerrada (8 semanas)

Objetivo: completar los módulos restantes y probar la plataforma con un grupo controlado de 50 usuarios reales. Entregables principales: módulo de pagos y facturación CFDI, módulo de recetas digitales con firma electrónica, módulo de mensajería, integración piloto con un EHR externo mediante FHIR. Criterios de salida: 50 usuarios activos durante 4 semanas, NPS sobre 30, tasa de errores en producción por debajo del 1%, ajustes incorporados.

10.4 Fase 3 - Piloto Productivo (8 semanas)

Objetivo: desplegar la plataforma en producción con la primera institución piloto y obtener la certificación de cumplimiento NOM-024. Entregables principales: sistema productivo en cloud multi-región, auditoría de cumplimiento externa, certificación NOM-024 obtenida o en proceso avanzado, primera institución operando. Criterios de salida: SLA cumplido durante 4 semanas consecutivas, auditoría de cumplimiento sin observaciones críticas, NPS institucional sobre 40.

10.5 Fase 4 - Escalamiento (12 semanas)

Objetivo: habilitar capacidades multi-tenant, white-label y marketplace de APIs para expansión geográfica. Entregables principales: arquitectura multi-tenant completa, módulo white-label funcional, portal de developers con documentación OpenAPI, SDKs oficiales publicados, primera expansión a otra región de México. Criterios de salida: al menos 2 instituciones white-label operando, 5 aplicaciones externas consumiendo APIs, dashboard de operaciones maduro.

11. Equipo, Metodología y Estándares de Calidad

11.1 Equipo recomendado

El equipo sugerido para la Fase 1 es: un Product Owner con experiencia en salud digital; un Tech Lead especializado en Node.js/NestJS; dos desarrolladores full-stack; un DevOps/SRE; un QA Engineer con experiencia en automatización; un Diseñador UX/UI con foco en accesibilidad; un Security Engineer a tiempo parcial; un Data Engineer a tiempo parcial; un Compliance Officer a tiempo parcial durante toda la fase y a tiempo completo en fases posteriores. Para Fases 2 y 3 se incorporan dos desarrolladores adicionales y un QA más. En Fase 4 se añaden un Engineering Manager y un Developer Advocate para el programa de APIs.

11.2 Metodología

Se adopta Scrum con sprints de dos semanas. Las ceremonias incluyen: daily standup (15 min), sprint planning (2h), sprint review (1h) y retrospective (1h). El Definition of Done incluye: código revisado por al menos un par, pruebas unitarias con cobertura sobre 80%, pruebas E2E para flujos críticos pasando, análisis SonarQube sin issues críticos, documentación OpenAPI actualizada, desplegable en staging. El Definition of Ready exige criterios de aceptación explícitos, diseño técnico acordado y dependencias resueltas.

11.3 Estándares de calidad de código

ESLint con configuración estricta (airbnb o estándar del equipo), Prettier para formato, TypeScript en modo estricto sin any implícito, SonarQube con quality gate que bloquea merges con issues críticos o cobertura por debajo del 80%, Husky para pre-commit hooks,

commitlint con conventional commits. Todos los pull requests requieren aprobación de al menos un revisor y superación del pipeline CI.

11.4 Estrategia de pruebas

Pruebas unitarias con Jest para lógica de negocio, cobertura mínima 80%. Pruebas de integración para cada microservicio con Testcontainers (PostgreSQL, Redis reales en contenedores efímeros). Pruebas E2E con Playwright cubriendo los flujos críticos (UC-01 a UC-15). Pruebas de carga con k6 simulando 1.000 usuarios simultáneos. Pruebas de seguridad con OWASP ZAP en cada release. Pruebas de aceptación con usuarios reales en Fases 2 y 3.

11.5 Gestión de la configuración y control de versiones

Git con GitHub como plataforma. Se adopta trunk-based development con feature flags para evitar ramas largas, salvo para features que requieran varios sprints, en cuyo caso se usan ramas feature/* con rebase periódico. Los commits siguen conventional commits (feat, fix, chore, docs, refactor, test, perf). Las versiones se etiquetan con semantic versioning y se generan changelogs automáticos.

11.6 Pipeline CI/CD

GitHub Actions como motor CI/CD. El pipeline por pull request ejecuta: lint, type-check, tests unitarios, tests de integración, análisis SonarQube, build de imágenes Docker, escaneo Trivy de vulnerabilidades. El pipeline de release a master añade: pruebas E2E, pruebas de carga en staging, despliegue a producción con estrategia blue-green, smoke tests post-despliegue. ArgoCD sincroniza el estado declarado en Git con el clúster Kubernetes mediante patrón GitOps.

12. Indicadores de Éxito y KPIs

12.1 KPIs de adopción

Los KPIs de adopción miden el crecimiento y engagement de usuarios: usuarios activos mensuales (MAU) y diarios (DAU); retención a D1, D7, D30 y M3; Net Promoter Score (NPS) medido trimestralmente; tiempo promedio desde registro hasta primera consulta; distribución de consultas por especialidad.

12.2 KPIs operativos

Los KPIs operativos miden el desempeño técnico y de procesos: tasa de no-show (objetivo: bajo 10%); tiempo promedio entre hora programada y hora real de inicio (objetivo: bajo 5 minutos); latencia p95 de video (objetivo: bajo 250 ms); uptime real (objetivo: 99,95%); Mean Time To Detect (MTTD) de incidentes (objetivo: bajo 5 minutos); Mean Time To Restore (MTTR) (objetivo: bajo 30 minutos).

12.3 KPIs clínicos

Los KPIs clínicos miden la calidad de la atención: satisfacción clínica del paciente (encuesta post-consulta, objetivo: sobre 4,5/5); tasa de incidentes clínicos por 1.000 consultas (objetivo: cero); adherencia a guías clínicas documentadas; tasa de reconsulta por mismo motivo en 7 días (objetivo: bajo 5%).

12.4 KPIs financieros

Los KPIs financieros miden el desempeño del negocio: Customer Acquisition Cost (CAC); Lifetime Value (LTV); ratio LTV/CAC (objetivo: sobre 3); payback period (objetivo: bajo 12 meses); margen por consulta; ingresos recurrentes mensuales (MRR) para suscripciones.

12.5 Tablero de control

Se implementa un tablero de control ejecutivo con acceso para producto, ingeniería y dirección, con actualización en tiempo real para KPIs operativos y diaria/semanal para KPIs estratégicos. El tablero incluye alertas automáticas cuando un KPI se desvía de su objetivo.

13. Conclusiones y Próximos Pasos

El análisis realizado permite emitir las siguientes conclusiones preliminares, sujetas a validación durante la Fase 0.

Viabilidad técnica: el proyecto es viable con el stack tecnológico recomendado (NestJS + React + PostgreSQL + WebRTC). La adopción de microservicios permite escalado independiente y mitigación de riesgos técnicos. La complejidad principal reside en el módulo de videoconsulta y en las integraciones con sistemas externos (CFDI, FHIR, e.firma), todas ellas abordables con proveedores especializados.

Viabilidad regulatoria: el proyecto es viable bajo el marco regulatorio mexicano (NOM-024, LFPDPPP) y compatible con HIPAA, RGPD y estándares ISO/IEC. La condición crítica es la contratación temprana de asesoría legal especializada en salud digital para confirmar la clasificación SaMD y trazar el camino de certificación ante COFEPRIS si aplica.

Viabilidad de mercado: el proyecto es viable en un mercado en crecimiento, con oportunidad de diferenciación en cumplimiento regulatorio y en la profundidad del expediente clínico conforme a NOM-024. El modelo dual B2C/B2B ofrece resiliencia ante fluctuaciones de demanda.

Recomendación final: iniciar el proyecto con la Fase 0 de descubrimiento y diseño, ajustando el alcance y presupuesto en función de los hallazgos. La decisión de avanzar a Fase 1 se tomará al cierre de la Fase 0, cuando se confirme la clasificación regulatoria y se firmen los BAAs necesarios.

Próximos pasos inmediatos: (1) validación de stakeholders y confirmación del patrocinador del proyecto; (2) conformación formal del equipo de la Fase 0; (3) kickoff de la Fase 0 con cronograma detallado; (4) contratación de BAA con el cloud provider seleccionado; (5) selección y contratación de asesoría legal especializada en salud digital; (6) conformación del comité clínico asesor; (7) definición del presupuesto detallado y plan financiero; (8) establecimiento del governance model del proyecto.

Supuestos y dependencias: este documento se basa en los supuestos de disponibilidad de equipo, presupuesto y patrocinio ejecutivo. Las dependencias externas críticas son: la confirmación regulatoria ante COFEPRIS, la firma de BAAs con cloud provider y subcontratistas, y la disponibilidad de PAC autorizado por el SAT para CFDI 4.0. Cualquier modificación en estos supuestos requiere revisión del presente documento.

Anexo A. Matriz de Trazabilidad de Requisitos

La siguiente tabla consolida los requisitos funcionales y no funcionales más significativos, con su módulo de pertenencia, prioridad, criterio de aceptación, caso de uso asociado y fase de implementación prevista. La matriz completa se mantendrá como documento vivo durante todo el proyecto.

ID Req	Módulo	Descripción breve	Prioridad	Tipo	Criterio de aceptación	Caso de uso	Fase
RF-AUTH-01	Autenticación	Registro de paciente con verificación	Must	Funcional	Token OTP validado en email y teléfono	UC-01	Fase 1
RF-AUTH-02	Autenticación	MFA obligatorio profesionales	Must	Funcional	Segundo factor configurado y verificado	UC-02	Fase 1
RF-PAC-01	Pacientes	Perfil demográfico con CURP	Must	Funcional	CURP validada con dígito verificador	UC-01	Fase 1
RF-PRO-01	Profesionales	Perfil público con especialidades	Must	Funcional	Perfil visible tras verificación	UC-02	Fase 1
RF-CIT-01	Citas	Reserva con selección de médico	Must	Funcional	Disponibilidad en tiempo real, bloqueo pesimista	UC-03	Fase 1
RF-CIT-02	Citas	Recordatorios automáticos	Must	Funcional	Recordatorios 24h y 1h antes	UC-03	Fase 1
RF-VID-01	Video	Videoconsulta WebRTC SFU	Must	Funcional	Video HD, audio Opus, latencia bajo 250ms	UC-06	Fase 1
RF-VID-02	Video	E2EE opcional	Must	Funcional	Claves por sesión sin acceso backend	UC-06	Fase 1
RF-ECE-01	Expediente	Notas de evolución con plantillas	Must	Funcional	Plantillas configurables, marca temporal	UC-07	Fase 1
RF-ECE-07	Expediente	Exportación FHIR/JSON y PDF	Must	Funcional	Exportación conforme NOM-024	UC-14	Fase 2
RF-REC-01	Recetas	Receta con e.firma avanzada	Must	Funcional	Firma válida conforme eIDAS/SAT	UC-08	Fase 2
RF-REC-03	Recetas	Receta especial para controlados	Must	Funcional	Controles adicionales conforme norma	UC-09	Fase 2

ID Req	Módulo	Descripción breve	Prioridad	Tipo	Criterio de aceptación	Caso de uso	Fase
RF-PAG-01	Pagos	Stripe y Mercado Pago	Must	Funcional	Tokenización PCI-DSS	UC-10	Fase 2
RF-PAG-03	Pagos	CFDI 4.0 con complementos	Must	Funcional	Generación vía PAC, envío SAT en tiempo real	UC-10	Fase 2
RF-MSG-01	Mensajería	Chat cifrado paciente-médico	Must	Funcional	Cifrado tránsito y reposo, adjuntos 10MB	UC-15	Fase 2
RF-INT-01	Integraciones	API REST FHIR R4	Must	Funcional	Recursos Patient, Encounter, Observation, etc.	UC-14	Fase 2
RF-ADM-01	Administración	Gestión de usuarios y roles	Must	Funcional	Roles multi-institucionales	—	Fase 1
RF-ADM-02	Administración	Multi-tenant segregado	Must	Funcional	Datos aislados por tenant	—	Fase 4
RNF-01	Seguridad	Cifrado reposo AES-256	Must	No Funcional	Todos los datos sensibles cifrados	—	Fase 1
RNF-04	Disponibilidad	SLA 99,95%	Must	No Funcional	Máx 22 min indisponibilidad mensual	—	Fase 3
RNF-12	Accesibilidad	WCAG 2.1 AA	Must	No Funcional	Cumplimiento verificado por auditor	—	Fase 1

Tabla A1. Matriz de trazabilidad de requisitos (extracto).

Anexo B. Glosario y Referencias

B.1 Glosario de términos

Se presenta a continuación el glosario completo de términos, siglas y acrónimos utilizados en el documento.

Término	Definición
BAA	Business Associate Agreement, contrato exigido por HIPAA entre el covered entity y todo proveedor con acceso a PHI
CFDI	Comprobante Fiscal Digital por Internet, formato de factura electrónica mexicana
CIE-10	Clasificación Internacional de Enfermedades, 10ª revisión, equivalente en español de ICD-10
COFEPRIS	Comisión Federal para la Protección contra Riesgos Sanitarios (México)
DICOM	Digital Imaging and Communications in Medicine, estándar para imágenes médicas
DPIA	Data Protection Impact Assessment, Evaluación de Impacto en la Protección de Datos
ECE	Expediente Clínico Electrónico
EHR	Electronic Health Record, Historia Clínica Electrónica en inglés
eIDAS	Reglamento europeo de identificación electrónica y servicios de confianza
e.firma	Firma electrónica avanzada del Servicio de Administración Tributaria (SAT, México)
E2EE	End-to-End Encryption, cifrado de extremo a extremo
FHIR	Fast Healthcare Interoperability Resources, estándar HL7 moderno basado en REST
HIPAA	Health Insurance Portability and Accountability Act (Estados Unidos)
HITECH	Health Information Technology for Economic and Clinical Health Act
HL7	Health Level Seven, organización y estándares de intercambio clínico
ICD-10	International Classification of Diseases, 10th revision
INAI	Instituto Nacional de Transparencia, Acceso a la Información y Protección de Datos Personales (México)
ISO 27001	Estándar internacional de Sistema de Gestión de Seguridad de la Información
ISO 14971	Estándar de gestión de riesgos para productos sanitarios
KYC	Know Your Customer, proceso de verificación de identidad
LFPDPPP	Ley Federal de Protección de Datos Personales en Posesión de los Particulares (México)
LOINC	Logical Observation Identifiers Names and Codes, terminología para observaciones de laboratorio
MDR	Medical Device Regulation, Reglamento UE 2017/745 de dispositivos médicos
MFA	Multi-Factor Authentication, autenticación multifactor
MTTD	Mean Time To Detect, tiempo medio de detección de incidentes
MTTR	Mean Time To Restore, tiempo medio de restauración

Término	Definición
NOM-024	Norma Oficial Mexicana SSA3-2012, expediente clínico electrónico
OIDC	OpenID Connect, protocolo de identidad sobre OAuth 2.0
RBAC	Role-Based Access Control, control de acceso basado en roles
ABAC	Attribute-Based Access Control, control de acceso basado en atributos
RGPD	Reglamento General de Protección de Datos (Unión Europea), equivalente a GDPR
RPO	Recovery Point Objective, punto objetivo de recuperación
RTO	Recovery Time Objective, tiempo objetivo de recuperación
SaMD	Software as a Medical Device, software como dispositivo médico
SAT	Servicio de Administración Tributaria (México)
SFU	Selective Forwarding Unit, componente de infraestructura WebRTC
SLA	Service Level Agreement, acuerdo de nivel de servicio
SMART on FHIR	Iniciativa para apps clínicas basadas en FHIR con autorización OAuth 2.0
SNOMED CT	Systematized Nomenclature of Medicine - Clinical Terms
SSO	Single Sign-On, inicio de sesión único
WebRTC	Web Real-Time Communications, estándar W3C para comunicación en tiempo real

Tabla B1. Glosario de términos y siglas.

B.2 Referencias bibliográficas y normativas

Las siguientes referencias bibliográficas y normativas fueron consultadas durante la elaboración del presente documento:

1. NORMA Oficial Mexicana NOM-024-SSA3-2012. Sistemas de información de registro electrónico para la salud. Intercambio de información en salud. Diario Oficial de la Federación, México. URL: https://dof.gob.mx/normasOficiales/4151/salud.htm

2. Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP). México, 2010.

3. Health Insurance Portability and Accountability Act (HIPAA), Privacy Rule y Security Rule. U.S. Department of Health and Human Services. URL: https://www.hhs.gov/hipaa

4. Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, RGPD/GDPR). Parlamento Europeo y Consejo de la Unión Europea.

5. Reglamento (UE) 2017/745 (Reglamento de Dispositivos Médicos, MDR). Parlamento Europeo y Consejo de la Unión Europea.

6. ISO/IEC 27001:2022. Information security management systems — Requirements. International Organization for Standardization.

7. ISO 14971:2019. Application of risk management to medical devices. International Organization for Standardization.

8. ISO 27799:2016. Health informatics — Information security management in health using ISO/IEC 27002. International Organization for Standardization.

9. HL7 FHIR R4 Specification. Health Level Seven International. URL: https://hl7.org/fhir/R4/

10. Web Real-Time Communications (WebRTC) W3C Recommendation. URL: https://www.w3.org/TR/webrtc/

11. Hospital Virtual de México (sitio de referencia). URL: https://www.hospitalvirtual.com.mx/

12. SAT. Comprobante Fiscal Digital por Internet (CFDI) versión 4.0. Servicio de Administración Tributaria, México.

13. WCAG 2.1 Web Content Accessibility Guidelines. W3C. URL: https://www.w3.org/TR/WCAG21/